

Secure Software Design and Development (CY321)

From Hello World to Hack-Proof

Life with Cybersecurity??

interesting



boring



About me!

Zubair Ahmad

Education

- Ph.D. in Computer Science (Cyber Security) - University of Venice Italy (2020-2024)
- Visiting Research Scholar - CISPAC Helmholtz Center for Information Security Germany
- European Parliament – EU AI Act 2023
- OPLSS Summer School Uni of Oregon and Boston Uni USA 2021

Research Interests

- Web Security and Privacy
- Data Privacy and Protection
- Internet and Web Measurements
- EU Compliance regulations, GDPR
- Internet of Things

More about me --> <https://zahmaad.github.io/>



Schedule



Course Pre-Req: CY201

When?

- Monday – 2:30 PM
- Tuesday – 11:30 AM
- Thursday – 12:30 PM

What?

- Lectures
- Quizzes/Project/Class Activities
- Mid/Final Exams

• Where?

- Here!
- LH8 AcB

Attendance?

- Active Attendance
- **Dead Bodies.**
- **Active Minds**
- Mobiles in hands → Mark as absent
- 80% mandatory
- **5 minutes threshold**
- **Dress Properly**

Webpage



- Lectures Slides
- Books
- Project
- Labs Material

ZAhmaad / Secure-Software-Design-And-Engineering

<> Code Issues Pull requests Actions Projects Wiki Security Insights

Secure-Software-Design-And-E... Public Pin Unwatch 1 Fork 5 Star 0

main Go to file + <> Code

JaziaSajid Add files via upload a43ff15 · 7 months ago

Code	Add code examples	last year
Guest Lecture	Guest lecture	10 months ago
Lecture Slides	Delete Lecture Slides/Week-8 dire...	8 months ago
Reference Books	Add Reference Books folder	last year
SSD LAB	Add files via upload	7 months ago
README.md	Update README.md	11 months ago

About

Secure Software Design and Engineering

Readme Activity 0 stars 1 watching 5 forks

Releases

No releases published

<https://github.com/ZAhmaad/Secure-Software-Design-And-Engineering>

CLO – GA Mapping

Sr. No.	Course Learning Outcomes (CLOs) ⁺	Graduate Attributes (GA)	Bloom's Taxonomy level (Cognitive domain)
CLO 1	Understand software security standards, models, processes and best practices that need to be incorporated throughout the software development lifecycle.	GA-3 (Problem Analysis)	C2 (Understanding)
CLO 2	Analyze and mitigate software vulnerabilities by implementing secure coding practices and automated security testing.	GA-5 (Modern Tool Usage)	C4 (Analyzing)
CLO 3	Apply secure software design principles in developing security solutions for real-world applications.	GA-4 (Design/Development of Solutions)	C3 (Applying)

Each CLO will mapped with Assessment Tool

Grading Policy

Assessment Items	Percentage
Quizzes	20%
Project	10%
Midterm Exam	30%
Final Exam	40%

Class Activity will not be marked. Its just to prepare for Quizzes/Exams

Quiz retake only in case of medical emergency. MC Doctor needs to email.

Assessment Mapping With CLOs

Assessment tools	CLO_1	CLO_2	CLO_3
Quizzes	50%	50%	-
Project	-	-	100%
Midterm Exam	50%	-	-
Final Exam	-	50%	-

Course Division

- Security in SDLC
- Software Vulnerabilities, Exploitation and Mitigation
- Security Testing
- Advanced Topics in Secure Software Design

Security in SDLC

Week 1	• Introduction to Secure Software Concepts • Importance of secure software design • Security in the Software Development Life Cycle (SDLC) • Security concepts integrated into SDLC phases	SSDLC Basic Concepts
Week 2	• Risk Management in Software Projects • Identifying, analyzing, and mitigating risks • Introduction to security standards	Risks Management
Week 3	• Security principles and secure design considerations • Designing secure design principles • Research Study	Security By Design
Week 4	• Security Mechanism • Mechanism and Policy • How to regulate access • The K.I.S.S Principle	Access Control

Software Vulnerabilities, Exploitation and Mitigation

Software Vulnerabilities, Exploitation and Mitigation

Week 5	• Common Software Vulnerabilities • Buffer overflow • Exploitation techniques and impacts
Week 6	• SQL injection • Exploitation techniques and impacts
Week 7	• Cross-site Scripting • Exploitation techniques and impacts
Week 8	• Supply Chain Attacks • Exploitation techniques and impacts

Security Testing

Week 9	• Secure Software Testing (1) • Testing concepts • Static analysis • Research Study	Security Testing
Week 10	• Secure Software Testing (2) • Dynamic analysis • Research Study	

Advanced Topics in Secure Software Design

Week 11	• API Security • OWASP API Security Top 10
Week 12	• Web security in the real world • Browser Security Mechanism • Building blocks for secure modern web applications.
Week 13	• Taxonomy and classification of adversarial attacks on ML • Threats and exploits
Week 14	• Security and Privacy Compliance in Software Design • Privacy by Design • Data Protection in Software

Advanced Topics in Secure Software Design

Reference Books

Reference books:

- [Designing Secure Software: A Guide for Developers](#) by Loren Kohnfelder (2023)
- Official (ISC)2 Guide to the CSSLP (latest)
- Software Security: Building Security In, 1st Edition by Gary McGraw

Additional books:

- Ross Anderson. Security Engineering. Wiley. 2nd edition.
- Mathias Paye. Software Security Principles, Policies, and Protection. (January 2019, v0.33)
- Theodor Richardson & Charles Thies. Secure Software Design. Jones & Bartlett Learning. 2013
- [Secure by Design](#) - Dan Bergh Johnson, Daniel Deogun, Daniel Sawano – Manning 2019
- [Architecture Patterns with Python](#) - Harry Percival, Bob Gregory – O'Reilly 2020

Semester Project

Important Notes

- **No Traditional Projects**
- Impactful Projects
- Will Share the list of Projects this week
- **Pitch your own Idea and convince me**
- Four Students per team
- Pre-mid Presentation
- Pre-Final Presentation

Start working on your project from right now

- Github
 - Overleaf
- } Project Documentation

- **Deadline:** 6th Sep Sunday 11:59 PM
- You have one chance to pitch your Idea
- Email me one page summary of your idea including the **novelty** and **potential impacts**

What Should you expect in this course?

- Secure Software Development Process
- Detect and Mitigate **Insecure** Programming Practices
Conduct **Security** Testing
- Advanced Topics in Secure Software
- Design/Develop a Security Solution

A Quick Starter Scenario (1)

High Value
Messaging System

Bank Own Staff

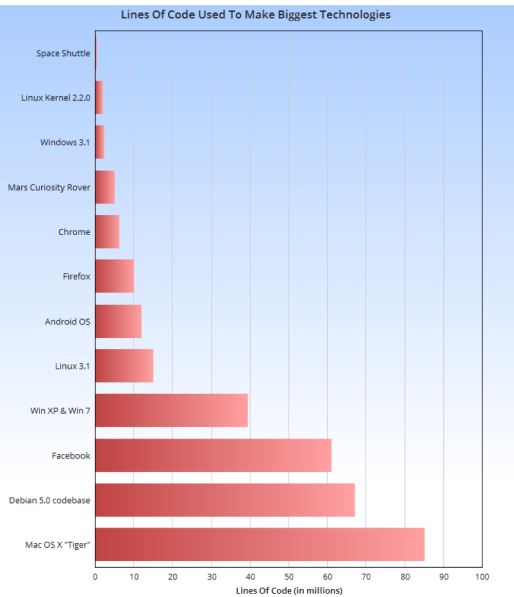


Physical Attack

ATM Machines

Website and
Mobile App

Why the problem is growing?



SOURCE: NASA, QUORA, WIKIPEDIA
INFORMATION IS BEAUTIFUL



Connectivity

Trinity of Troubles

Extensibility

Complexity

Navigating the Hurdles

Iron Triangle Constraints

Security as an Afterthought

Security Versus Usability

Iron Triangle Constraints

The **attacker** has the upper hand

Software development in and of itself is a resource, schedule (time) and budget intensive process

Resources (people) with appropriate skills and technical knowledge are not always readily available and are costly.

Scope = What we are building.

Time = When the software needs to be delivered.

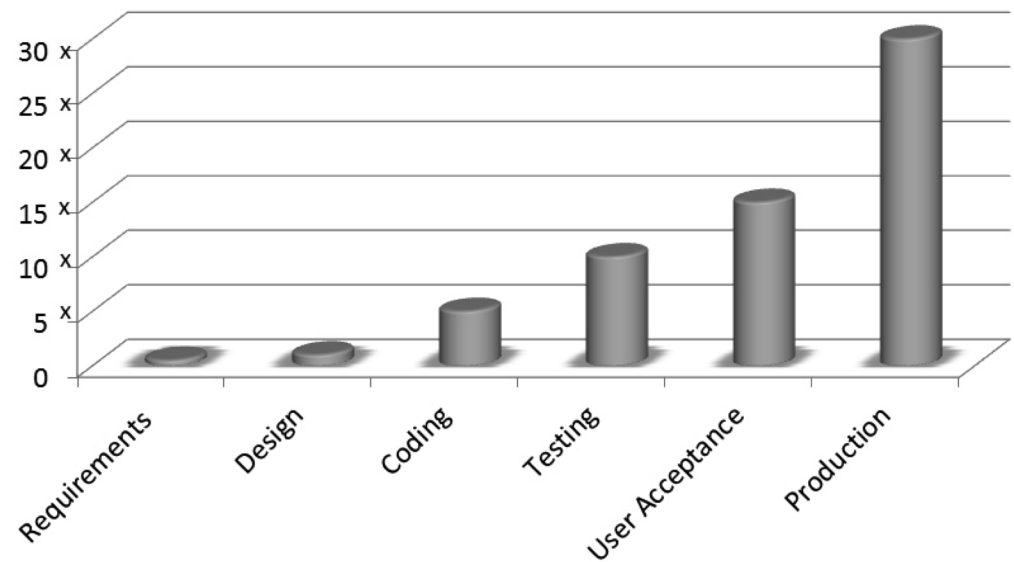
Cost = Available budget and resources.



Security as an Afterthought

- **Security** does not add any **business value**
- **Secure** features should be added at initial stage, instead at a later stage,

Relative Cost of Software Defects



Security Versus Usability

More Security = Less Usability

- Secure features is viewed as rendering the software to become very **complex, restrictive and unusable**
- A software product that is secure will add to the **quality** of that software but the inverse is not always necessarily true

Questions?

zahmaad.github.io